# StudyTrack | Deliverable 1

CPE 334 - Engineering baseline and working Sprint 1. Theme 8: Habit and Activity Tracking System; context: personal reading habits. Prepared 6 November 2026; deadline 8 November 2026, 23:59 Asia/Bangkok.

DELIVERABLE 1 - VERIFIED RELEASE

Repository: https://github.com/auto4496/studytrack

Submitted main commit: df08ec19cdeb0efcfbfbee92f3d385d87059528c; tag: v0.1.0-sprint1.

| Member | Student name / ID | GitHub |
|---|---|---|
| 1 | Phanuwit Butchari / 67070501070 | auto4496 |
| 2 | Pitchai Chadchuangchot / 67070501068 | Datakung |

Student names and full IDs are supplied by the team. The report begins with project information and navigation, followed immediately by Part A.

Schedule note: Submit one self-contained PDF per team through LEB2 by 8 November 2026 at 23:59 Asia/Bangkok.

| Part | Pages | Required content / IDs |
|---|---|---|
| A | 1-4 | SRS; FR01-19 / BR01-13 / NFR01-08 |
| B | 5-7 | F01-08 inventory and complete allocation |
| C | 8-10 | Architecture/data/auth/UI/API/deployment plan |
| D | 11-11 | Three-sprint goals/dependencies/outcomes |
| E | 12-19 | F01-04 / AC / STS / Product DoD |
| F | 20-32 | Demonstrations/results/history/contributions |

# Part A. SRS and product scope

## A1. Problem, context and actors

Students need a small, reliable way to set daily reading goals, record actual minutes and see whether they met the appropriate target. StudyTrack provides shared activity templates while keeping each participant's goals and activity history private.

Participant: creates and reads own goals, records/corrects own activity, and uses own history, schedule and summaries. Program Manager: maintains the shared template catalog, without access to participant goals/history. Anonymous visitor: starts authentication and sees no protected data. One account has one role. Synthetic seed has one manager and two participants.

## A2. Whole-product scope and exclusions

The baseline includes identity/access, templates, goals, daily activity/progress, target/lifecycle revisions, history/corrections/streaks, persisted schedule/reminder representation and summaries across three sprints. Sprint 1 delivers F-01..F-04 as one UI/API/PostgreSQL journey. Later features are allocated now rather than silently dropped.

Excluded: social sharing, leaderboards, AI advice, medical advice/diagnosis, file uploads, external integrations and email/SMS/push delivery. Self-registration, password recovery and email verification are outside the seeded-account baseline. Reminders are represented in-app. No manager consent-based sharing feature is specified.

## A3. Functional requirements

| ID | Observable behavior | Allocation |
|---|---|---|
| FR-01 | Valid account/password login creates a new authenticated session; invalid credentials do not. | F-01 / S1 |
| FR-02 | Logout revokes the current session so it cannot access protected APIs again. | F-01 / S1 |
| FR-03 | Retrieve current identity/role; anonymous or expired sessions receive no private identity. | F-01 / S1 |
| FR-04 | Authenticate, authorize roles and enforce ownership at the API. Managers do not gain access to participant records. | F-01..08 / S1-3 |
| FR-05 | Manager creates a minute-based activity template with valid name and bounds. | F-02 / S1 |
| FR-06 | Participant browses active template list/detail; manager may include inactive templates in the shared catalog. | F-02 / S1 |
| FR-07 | Participant creates a goal from an active template with a valid daily target and start date. | F-03 / S1 |
| FR-08 | Participant retrieves the saved list/detail of their own goals. | F-03 / S1 |
| FR-09 | Change daily target effective tomorrow while preserving historical targets. | F-05 / S2 |
| FR-10 | Stop a goal; manager deactivates/updates template metadata without destroying history. | F-05 / S2 |
| FR-11 | Record one integer-minute entry per goal/date and retrieve the committed entry. | F-04 / S1 |
| FR-12 | Display actual, date-effective target, percentage and achieved state for a goal/date. | F-04 / S1 |
| FR-13 | Browse own activity history filtered by goal/date range. | F-06 / S2 |
| FR-14 | Correct own recorded minutes under domain rules; progress/history/streak remain consistent. | F-06 / S2 |
| FR-15 | Calculate current/best goal streak using local dates and each date's effective target. | F-06 / S2 |
| FR-16 | Configure intended reading weekdays and local time per own goal. | F-07 / S3 |
| FR-17 | Display persistent schedules and in-app reminder state in Asia/Bangkok; no external delivery. | F-07 / S3 |
| FR-18 | Summarize own minutes and achieved days over a selected period without mixing other users. | F-08 / S3 |
| FR-19 | Expose loading, empty, validation, forbidden/session-expired and server-error states with appropriate recovery. | F-01..08 / S1-3 |

## A4. Business rules

| ID | Required invariant | Allocation |
|---|---|---|
| BR-01 | MINUTES only. Integer template bounds 1..1440; min<=max. Trim title to 1..100 Unicode code points; description <=500. | F-02 / S1 |
| BR-02 | Target is an integer within template bounds. Start is today/tomorrow in Bangkok. Snapshot unit, title and range on creation. | F-03 / S1 |
| BR-03 | At most one ACTIVE goal per participant/template, including a future-start goal and competing creates. | F-03 / S1 |
| BR-04 | UNIQUE(goalId, entryDate). Sequential or concurrent duplicates reject 409; never overwrite the first entry. | F-04 / S1 |
| BR-05 | Entry date is a real YYYY-MM-DD from start through today; integer minutes obey immutable goal bounds. | F-04 / S1 |
| BR-06 | Progress=actual/target*100, HALF_UP to two decimals, uncapped. Achieved uses actual>=target; no entry means actual0/false. | F-04/F-08 / S1/3 |
| BR-07 | Owner/user/role come only from server identity. Manager at participant APIs gets403; cross-owner resource gets non-disclosing404. | F-01..08 / S1-3 |
| BR-08 | Target revision starts tomorrow. Old dates keep old targets. Repeated pending revision updates that day's version. | F-05 / S2 |
| BR-09 | Streak counts consecutive achieved local dates; today incomplete may leave current streak ending yesterday; best covers all history. | F-06 / S2 |
| BR-10 | Inactive template blocks new goals; existing goals continue from snapshots. Used template unit/bounds are not changed; create a new template. | F-05 / S2 |
| BR-11 | Stopped goal preserves endDate/history. Entry/correction allowed only start..min(endDate,today). Archived goals do not reopen. | F-05/F-06 / S2 |
| BR-12 | History/summary ranges include both endpoints; from<=to. User-level achieved-day count deduplicates local dates across goals. | F-06/F-08 / S2/3 |
| BR-13 | Schedule weekdays1=Mon..7=Sun are unique; HH:mm is valid Bangkok time. A planned schedule never proves an activity occurred. | F-07 / S3 |

## A5. Measurable non-functional requirements

| ID / scope | Measurable target | Verification checkpoint |
|---|---|---|
| NFR-01; F-01..08 / 1-3 | Every released protected endpoint: anonymous401, wrong role403, cross-owner404 with no private fields. | API access matrix in S1; extend S2/S3. |
| NFR-02; F-01 / 1 + Lab5 | Argon2id salted password hashes; HttpOnly/SameSite=Lax cookie, Secure over production HTTPS. Expiry/revocation and CSRF reject unsafe requests. | DB/config and session/CSRF integration in S1; deployment recheck. |
| NFR-03; Persistence / 1-3 | Accepted template/goal/entry persists after API restart; on GCP it survives expected redeployment. | Real process restart in S1; cloud restart/redeploy in Lab5/final. |
| NFR-04; Reproduction / 1-3 | Fresh documented checkout can install/setup/migrate/seed/build/run/test without application-source edits; repeated seed does not duplicate users. | Fresh setup and idempotent seed in S1/final. |
| NFR-05; Quality / 1-3 | Every released AC has actual test/result/version; required failures/skips are disclosed. From Lab5, failing required CI check blocks release. | AC ledger in S1; controlled CI failure in Lab5. |
| NFR-06; UI / 1-3 | Critical S1 screens work at390x844 and1440x900 without horizontal overflow, with labels/focus/field errors. | Selected browser journeys/screenshots; extend new screens. |
| NFR-07; Secrets / 1-3 | Git/report/logs contain no real passwords, credentials or session/CSRF tokens. Examples use placeholders. | Inspect changed configuration and retained evidence each release. |
| NFR-08; Clock/rules / 1-3 | Date/progress logic uses one Bangkok calendar. Fixed-clock tests cover23:59/00:00, invalid days and month/year transitions. | Unit/API in S1; extend streak/schedule/summary in S2/S3. |

## A6. Assumptions, decisions and open questions

DEC-01: Theme8/reading context selected by the team; integer MINUTES gives explicit testable bounds. DEC-02: one new StudyTrack repository/database, separate from TokTickIT. DEC-03: A owns F01/F03/foundation and B owns F02/F04, with cross-review; responsibilities rotate in later work. DEC-04: SRS FR01..19/BR01..13/NFR01..08 are the authoritative stable IDs.

DEC-05: same-origin modular monolith, React/Vite plus Express/TypeScript and PostgreSQL/Prisma. DEC-06: server-side opaque sessions, Argon2id, synchronizer CSRF and exact Origin checks. DEC-07: snapshot template title/unit/bounds and version targets by effective date. DEC-08: domain dates use Asia/Bangkok and PostgreSQL DATE; audit timestamps use UTC. DEC-09: version contracts/tests before implementation and retain actual red/green history. DEC-10: the initial lack of a shared repository was resolved by creating auto4496/studytrack and adding Datakung; it is a historical decision, not a current blocker.

Resolved on 4 November: both student identities supplied, release PR9 approved and merged to main. Current open items are later cloud resources/cost/access, independent UAT partner and TA-approved maintenance change. Conflicting final-video length/rubric in later handouts must be clarified before final delivery; this does not change D1. No unsupported performance SLA is claimed. Scope changes require rationale, affected IDs and review; no scope deletion has been approved in this increment.

# Part B. Feature inventory and traceability

## B1. Complete product feature inventory

| Feature / outcome | Sprint / lead | Dependencies |
|---|---|---|
| F-01 Identity and access. Login/logout/me; session rotation, expiry/revocation, role/ownership foundation. | 1 / A | Shared schema/config/seed |
| F-02 Activity templates. Manager create and persisted active catalog/detail; validated minute ranges. | 1 / B | F-01; shared DTO/auth |
| F-03 Personal goals. Create/read own goals with snapshots, initial target and concurrent ACTIVE uniqueness. | 1 / A | F-01, F-02 |
| F-04 Entries and progress. One daily entry, date-effective target, unbounded progress and recovery. | 1 / B | F-01, F-03 |
| F-05 Goal/template lifecycle. Tomorrow-effective target revision, stop/archive goal, deactivate/metadata rules. | 2 / A | F-02, F-03, F-04 |
| F-06 History and streak. Filter/correct own entries; recompute date-effective current/best streak. | 2 / B | F-04, F-05 |
| F-07 Schedule/reminder. Persistent weekdays/time and in-app reminder representation. | 3 / A | F-03, F-05 |
| F-08 Summary/completion. Persisted period summaries and integrated hardening; genuine domain calculations. | 3 / B | F-04, F-05, F-06 |

## B2. Requirements-to-feature-to-sprint mapping

S1 means implemented, checked and accepted through reviewed release PR9 on the named main commit. S2/S3 are allocated, with detailed contracts/tests required before their implementation.

| Requirement IDs | Feature / sprint | Verification / current scope |
|---|---|---|
| FR-01 | F-01 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-02 | F-01 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-03 | F-01 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-04 | F-01..08 / S1-3 | Cross-cutting S1 checks; extend new routes in S2/S3 |
| FR-05 | F-02 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-06 | F-02 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-07 | F-03 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-08 | F-03 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-09 | F-05 / S2 | Planned contract and domain/API/UI checks before code |
| FR-10 | F-05 / S2 | Planned contract and domain/API/UI checks before code |
| FR-11 | F-04 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-12 | F-04 / S1 | F01/F02/F03/F04 AC and actual result ledger in Part F |
| FR-13 | F-06 / S2 | Planned contract and domain/API/UI checks before code |
| FR-14 | F-06 / S2 | Planned contract and domain/API/UI checks before code |

| Requirement IDs | Feature / sprint | Verification / current scope |
|---|---|---|
| FR-15 | F-06 / S2 | Planned contract and domain/API/UI checks before code |
| FR-16 | F-07 / S3 | Planned contract and domain/API/UI checks before code |
| FR-17 | F-07 / S3 | Planned contract and domain/API/UI checks before code |
| FR-18 | F-08 / S3 | Planned contract and domain/API/UI checks before code |
| FR-19 | F-01..08 / S1-3 | Cross-cutting S1 checks; extend new routes in S2/S3 |

| Requirement IDs | Feature / sprint | Verification / current scope |
|---|---|---|
| BR-01 | F-02 / S1 | F02 validation and F03/F04 snapshot tests |
| BR-02 | F-03 / S1 | F03 AC01/03/07: create/date/target |
| BR-03 | F-03 / S1 | F03 AC05: one winner under concurrency |
| BR-04 | F-04 / S1 | F04 AC06/07: duplicate/concurrent |
| BR-05 | F-04 / S1 | F04 AC04/05: date/snapshot bounds |
| BR-06 | F-04/F-08 / S1/3 | F04 AC03: HALF_UP/125%; S3 summary planned |
| BR-07 | F-01..08 / S1-3 | All S1 role/owner/forged-field tests; extend S2/S3 |
| BR-08 | F-05 / S2 | S1 historical-target consumer verified; revision mutation planned S2 |
| BR-09 | F-06 / S2 | Streak contract/test matrix planned S2 |
| BR-10 | F-05 / S2 | S1 inactive/snapshot consumers checked; lifecycle writes planned S2 |
| BR-11 | F-05/F-06 / S2 | S1 archived fixture bounds checked; lifecycle/correction planned S2 |
| BR-12 | F-06/F-08 / S2/3 | Period/deduplicated-day rules planned S2/S3 |
| BR-13 | F-07 / S3 | Weekday/time/persistence rules planned S3 |

| Requirement IDs | Responsibility / sprint | Verification / current scope |
|---|---|---|
| NFR-01 | F-01..08 / 1-3 | API access matrix in S1; extend S2/S3. S1 evidence in Part F; extend at later checkpoint. |
| NFR-02 | F-01 / 1 + Lab5 | DB/config and session/CSRF integration in S1; deployment recheck. Local checks recorded; cloud portion pending. |
| NFR-03 | Persistence / 1-3 | Real process restart in S1; cloud restart/redeploy in Lab5/final. Local checks recorded; cloud portion pending. |
| NFR-04 | Reproduction / 1-3 | Fresh setup and idempotent seed in S1/final. S1 evidence in Part F; extend at later checkpoint. |
| NFR-05 | Quality / 1-3 | AC ledger in S1; controlled CI failure in Lab5. Local checks recorded; cloud portion pending. |
| NFR-06 | UI / 1-3 | Selected browser journeys/screenshots; extend new screens. S1 evidence in Part F; extend at later checkpoint. |

| Requirement IDs | Responsibility / sprint | Verification / current scope |
|---|---|---|
| NFR-07 | Secrets / 1-3 | Inspect changed configuration and retained evidence each release. S1 evidence in Part F; extend at later checkpoint. |
| NFR-08 | Clock/rules / 1-3 | Unit/API in S1; extend streak/schedule/summary in S2/S3. S1 evidence in Part F; extend at later checkpoint. |

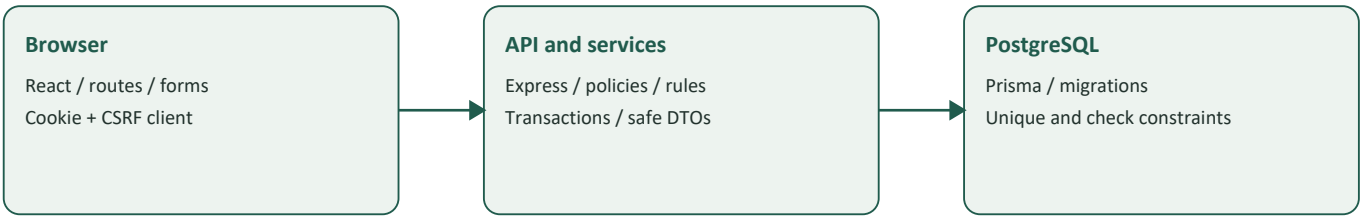
## B3. Coverage and change status

All19 FR,13 BR and8 important NFR have a feature or named system responsibility and sprint allocation. There are no intentionally uncovered baseline requirements. Later-sprint allocation does not mean implementation. BR08/10/11 have S1 read/consumer fixtures; their revision/deactivation/archive mutation workflows remain F05/F06 work. Cloud/CI/UAT/maintenance checkpoints remain pending. B's v0.2 mappings preserved A's IDs; historical draft text is not current acceptance. Scope is unchanged; final main release metadata and both student identities are now recorded. Final PDF checking and course submission remain.

# Part C. System-Level SDS

## C1. Architecture and responsibilities

React19/Vite8/TypeScript provides the browser UI, routes and shared API/auth client. Express5/TypeScript handles cookie sessions, identity/role/ownership policies, strict request validation, safe DTOs and errors. Feature services enforce date/target/snapshot rules and transactions. Prisma6.19.3 accesses PostgreSQL17. Database unique/check constraints protect persisted invariants under competing requests.




Same-origin /api | Server authority | Durable database separate from application lifecycle

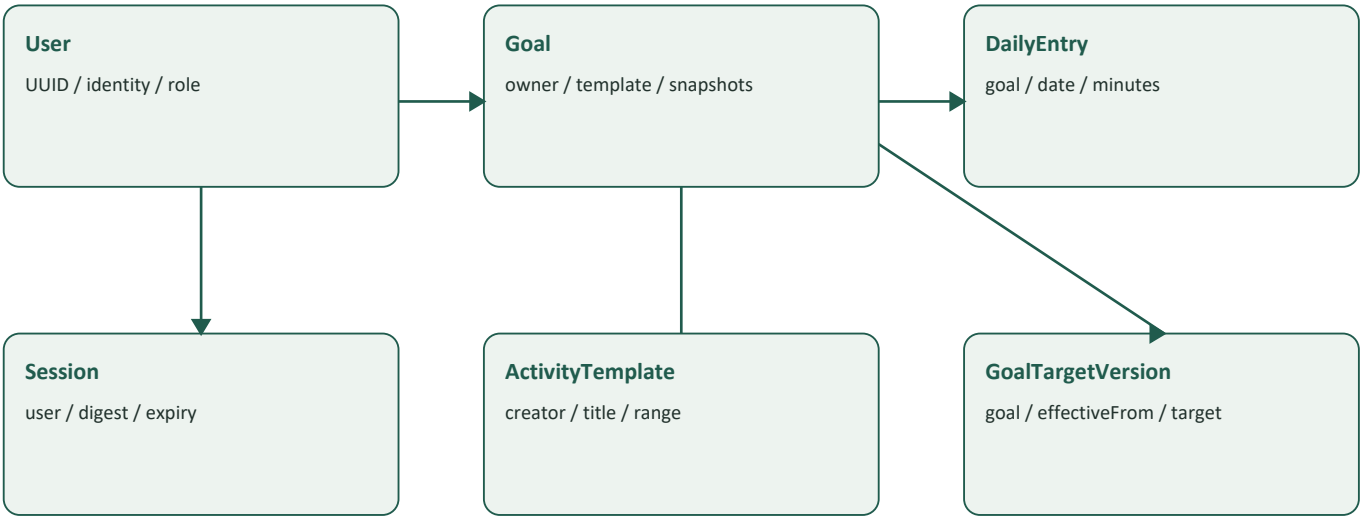
Development uses one browser origin and Vite /api proxy to Express. Production build is served by the same Express application. Durable PostgreSQL is separate from the disposable application process/container. The browser never supplies authoritative owner/role or progress calculations.

## C2. Data model and constraints

UUID IDs, snake_case database names and camelCase JSON. Domain dates are DATE/ISO YYYY-MM-DD; timestamps are timestamptz/UTC. The following six entities exist in Sprint1; schedule is a future extension.

| Entity / relationships | Important fields | Constraints / responsibility |
|---|---|---|
| User | id,emailNormalized,displayName,passwordHash,role,createdAt | Unique normalized email; PARTICIPANT/PROGRAM_MANAGER; hash excluded from DTO. |
| Session -> User (nullable) | id,tokenHash,csrfToken,userId,createdAt,expiresAt | Unique hashed token; null user for pre-auth CSRF; expired/revoked session denied. |
| ActivityTemplate -> creator User | id,title,description,unit,minMinutes,maxMinutes,isActive,createdById,timestamps | MINUTES; 1<=min<=max<=1440; title1..100; creator FK; manager checked in API. |
| Goal -> owner User/template | id,ownerId,templateId,titleSnapshot,unit,min/maxSnapshot,startDate,endDate,status,createdAt | Partial unique(ownerId,templateId) WHERE status=ACTIVE; immutable historical context. |
| GoalTargetVersion -> Goal | id,goalId,effectiveFrom,targetMinutes,createdAt | Unique(goalId,effectiveFrom); initial version at startDate; latest version <=requested date. |
| DailyEntry -> Goal | id,goalId,entryDate,minutes,createdAt,updatedAt | Unique(goalId,entryDate); positive integer<=1440; service checks own goal, snapshot bounds/date. |
| GoalSchedule (planned S3) | goalId,weekday,localTime | Unique(goalId,weekday); weekday1..7/HH:mm; not in current schema. |

1 User -> many Goals / Sessions / Templates; 1 Goal -> many Entries and TargetVersions




GoalSchedule is planned for Sprint 3 and is not an implemented entity in this schema.

Goal+initial target are created atomically. Entry insertion locks the owned goal FOR SHARE, checks bounds/target and inserts in one transaction; PostgreSQL uniqueness supplies the one-winner guarantee. Progress/list reads use repeatable-read snapshots. Known unique conflicts map to409; unexpected failures roll back and return safe500. A foreign key alone does not enforce role, template-active state or cross-table date/range rules. Later lifecycle writers must use a compatible row-lock order. No S1 deactivate endpoint exists.

Versioned SQL migrations include check/partial unique constraints not fully expressible in the ORM schema. Apply immutable migrations with migrate deploy; future changes add a migration. Seed upserts three synthetic users and two templates, does not reset existing records/passwords. Automated suites use guarded isolated databases, never development.

## C3. UI/navigation and common states

Routes: /login; /manager/templates; /manager/templates/new; /templates; /goals; /goals/new; /goals/:goalId. Later contracts add lifecycle/history/schedule/summary views. Role navigation comes from trusted /auth/me; no role dropdown or owner selector. Labels and visible keyboard focus identify inputs, field errors retain values, pending disables repeated submits, and loading/empty/error/success are distinct. 401 clears private auth state and offers login without replaying mutations. 403/404 show safe messages; backend still enforces access.

Date inputs send Bangkok date-only strings. Future-start goal shows a notice without an invalid entry fetch. Saved dates show persisted progress; a late response cannot replace a newly selected date. Lost POST responses reconcile via GET before another write. Template titles may duplicate, so unknown template-create outcomes require catalog inspection and do not claim exactly-once creation. Progress label can exceed100%; the visual bar caps at100%.

## C4. API conventions and DTOs

Same-origin JSON UTF-8 under /api, no permissive CORS. Unsafe authenticated JSON requests require cookie, exact configured Origin, X-CSRF-Token and Content-Type:application/json. Success is {data:DTO}; collections add meta:{page,pageSize,total}; logout204 has no body. Bounded pagination defaults1/20 with pageSize<=100; deterministic sorts. Unknown body/query keys reject on the documented strict surfaces. Invalid JSON/UUID/date syntax400; invalid values422; anonymous401; wrong role/CSRF/origin403; missing/cross-owner404; duplicate409; unsupported body415; safe unexpected500. Error={error:{code,message,fields?:{field:string},requestId}}. Request body limit16KiB.

UserDTO exposes id,email,displayName,role. TemplateDTO exposes id,title,description,unit,minMinutes,maxMinutes,isActive,createdAt,updatedAt. GoalDTO exposes id,templateId,templateTitle,unit,minMinutes,maxMinutes,startDate,endDate,status,targetMinutes,targetEffectiveFrom,createdAt. EntryDTO exposes id,goalId,entryDate,minutes,targetMinutes,progressPercent,achieved,createdAt,updatedAt. No password/session digest or server creator/owner impersonation input is exposed. GoalDTO's target is current (initial for future-start); EntryDTO resolves the entry date's version.

| Operation | Participant | Manager / anonymous |
|---|---|---|
| GET auth/csrf; POST auth/login | Bootstrap/valid credentials, CSRF+Origin | Same login flow; anonymous bootstrap allowed |

| Operation | Participant | Manager / anonymous |
|---|---|---|
| GET auth/me; POST auth/logout | Own authenticated identity/session | Own authenticated identity/session; anonymous401 |
| GET templates/list/detail | Active only; includeInactive=true403 | Shared catalog; inactive filter/detail allowed; anonymous401 |
| POST templates | 403 even forged role | Manager201 with strict payload; anonymous401 |
| POST/GET goals; GET goal detail | Own only; cross-owner detail404 | 403; anonymous401 |
| POST/list entries; GET progress | Own goal only; cross-owner404 | 403; anonymous401 |

## C5. Authentication lifecycle and ownership

Passwords are Argon2id with unique salt, memory19456KiB, iterations2, parallelism1. Fixture strings are synthetic; seed passwords are private environment values. Invalid email/password share generic401. Session cookie holds random32-byte base64url ID; database stores SHA256 token digest and a separate random CSRF token. Pre-auth session lasts30min; valid login rotates/revokes prior session and CSRF then issues fixed8h session. Expiry is enforced server-side, not sliding client time. /auth/me reads identity, /auth/csrf bootstraps token and auth endpoints are no-store. Logout deletes current DB session and clears cookie; replay fails, independent sessions remain valid.

Cookie studytrack.sid is HttpOnly, SameSite=Lax, Path=/ with no Domain; Secure in production HTTPS. Exact Origin and synchronizer token protect unsafe requests, including login. Role is read from trusted user record. Private goal lookup scopes id AND ownerId; manager never bypasses that policy. DTO allowlists, safe errors and request IDs avoid credential/private-row leakage.

## C6. Configuration, deployment and verification design

| Variable | Purpose / handling |
|---|---|
| DATABASE_URL | Private PostgreSQL URL for application; durable DB outside app filesystem. |
| TEST_DATABASE_URL | Different PostgreSQL DB with explicit test marker; isolated destructive fixtures only. |
| APP_ORIGIN / PORT / NODE_ENV | Exact browser origin, API port, development/test/production mode; never client-owned policy. |
| POSTGRES_PASSWORD | Private local Compose credential; generated, ignored, not in PDF. |
| SEED_MANAGER_PASSWORD / SEED_PARTICIPANT_PASSWORD | Private generated synthetic-account seed passwords; placeholders refused. |
| API_PROXY_TARGET / PLAYWRIGHT_CHANNEL | Local dev proxy/browser configuration; not secrets. |

Plan for Lab5: package the production build as a stateless application container; use HTTPS container hosting and managed PostgreSQL on GCP with external secret configuration, durable database storage and controlled migrations. Add PR build/tests, required failed-check gate proof, repeatable accepted-main delivery, health/version identification and post-deploy normal/rejection/access/persistence checks. Exact resources, IAM/cost and workflow require the delivery checkpoint; none are provisioned or claimed complete here. No completed Docker app, CI/CD, cloud URL or demo video is required for D1.

Unit checks cover important logic; API+real PostgreSQL covers transactions, constraints, auth/ownership; selected browser journeys cover critical flows and state recovery. Independent UAT is performed by another real team in Lab6, not inferred from automation.

# Part D. Three-sprint plan

## D1. Goals, allocation and completion outcomes

| Sprint / checkpoint | Features, lead and dependencies | Completion outcome |
|---|---|---|
| 1: by8Nov | F01 A -> F02 B -> F03 A -> F04 B. Shared identity/schema/DTO/date rules; peer review across owners. | Working manager-template -> participant-goal -> entry -> persisted progress, negative/access/concurrency checks, reviewed staging/main release and A-F PDF. |
| 2: internal9-22Nov; complete by29Nov | F05 A lifecycle/target changes -> F06 B history/correction/streak. Depends on accepted S1 and agreed version/snapshot/stop semantics. | Every F05/F06 AC implemented, tested/reviewed/integrated; historical calculations unchanged by later target revisions; deployed candidate for D2. |
| 3:23Nov-13Dec; progress29Nov | F07 A schedule/reminder; F08 B real summary/integration. F07 dependsF03/F05; F08 dependsF04/F05/F06. | ByD2 both contracts and >=1 meaningful implemented/tested workflow/rule; byFinal complete baseline, failure/access/usability/regression/UAT/deployment/docs. |

## D2. Feasibility, gates and shared work

S1 is deliberately one complete vertical slice instead of many empty screens: seed identities, one unit, explicit date/duplicate rules, no registration/recovery/social/external delivery. Contracts/test design can proceed while dependencies are being implemented; authoritative access/persistence evidence must use the actual API/database. Each owner performs requirements/design/tests/code and reviews the other; no permanent frontend/backend-only learning role.

The original internal plan reserved4-6Nov for implementation,7Nov for candidate checks and8Nov for release/submission. Actual feature and release reviews completed on4Nov; the accepted main is verified and tagged. Remaining work is joint PDF review and one LEB2 team submission before8Nov23:59.

9-15Nov: A leads Docker/persistence/config, B leads CI/gate/deploy, both exercise delivery.9-22Nov: F05/F06 parallel with Lab6; at least4 cross-team cases and an accepted defect fix plus independent retest.17-29Nov: instructor/TA-approved change to implemented behavior for Lab7, with impact/contract/red-green/regression/redeploy and five dated metrics.23-29Nov: real S3 progress alongside completed S2 and deployed D2. Aim for near-complete product by29Nov before1-11Dec exams;12-13Dec bounded fixes/final regression/report/video.

Risk controls: resolve shared schema/auth/DTO changes before dependent code; compatible lock order for lifecycle; preserve actual failure reports and current-source results; identify owner/dependency/next date for bounded remaining work. Do not replace a baseline feature with generic hardening. If independent UAT finds no real defect, consult TA rather than inventing one. Equal commit counts are not required.

# Part E. Sprint 1 engineering contracts

The following contracts contain feature design, applicable UI/API/data, stable AC, planned STS and DoD directly in this PDF. Original pre-implementation version/status is historical. F01/F03 began in11cdfe5; B drafts e3714d0 were reconciled inee14477 before F02/F04 code. PartF maps planned IDs to actual consolidated files/names/results. Final-head peer acceptance and release history are explicitly separate from pre-code design.

## E0. Shared transport and exact endpoints

| Method / path | Input and result | Key failure outcomes |
|---|---|---|
| GET /api/auth/csrf | data:{csrfToken,expiresAt}; anonymous pre-auth cookie if needed | Safe internal500 |
| POST /api/auth/login | {email,password}+CSRF/origin ->200 user,csrfToken,expiresAt; rotate cookie | Credentials401, validation422, CSRF/origin403 |
| GET /api/auth/me; POST /api/auth/logout | Authenticated identity200; revoke/logout204 | Anonymous/expired401; unsafe token/origin403 |
| GET /api/templates; GET /:templateId | Authenticated catalog/detail; page/pageSize; manager includeInactive=true | Anonymous401; participant inactive filter403; missing/invisible404 |
| POST /api/templates | Manager {title,description?,minMinutes,maxMinutes}->201 TemplateDTO | 401/403/422; server owns unit/status/creator |
| POST /api/goals | Participant {templateId,dailyTargetMinutes,startDate}->201 GoalDTO | Missing404,inactive422,range/date422,ACTIVE duplicate409 |
| GET /api/goals; GET /:goalId | Own list/detail; bounded page/pageSize/status | 401/403; cross-owner/missing404 |
| POST /api/goals/:goalId /entries | Own {entryDate,minutes}->201 EntryDTO | Date syntax400, bounds422,duplicate409,401/403/404 |
| GET /api/goals/:goalId/entries | Own paged EntryDTO[] + meta; date DESC/id ASC | Invalid query422;401/403/404 |
| GET /api/goals/:goalId/progress?date=YYYY-MM-DD | goalId,date,actualMinutes,targetMinutes,progressPercent,achieved,entryId/null | Required date; same date bounds;401/403/404/400/422 |

## F-01 engineering contract

Contract content recorded before implementation. Current review/merge and actual execution are in Part F. Planned filenames in the historical STS may differ from consolidated actual filenames; stable TEST and AC IDs are retained.

### 1. Behavior and dependencies

User opens login, obtains pre-auth CSRF session, submits email/password. Valid credentials rotate session and CSRF token, return safe identity and show role navigation. `/auth/me` recovers identity after reload. Logout revokes current session and returns to login. Invalid login returns generic error; expired session returns401 and offers login without automatically replaying mutation

Needs schema/User+Session, migrations, synthetic seed, config, clock, DB test isolation and common error mapper. These are A foundation tasks; F-02/F-03/F-04 depend on trusted principal/middleware. Role+ownership policy delivered here as foundation, feature-level access cases must also be executed against real endpoints

### 2. UI/API/data specifications

• UI `/login`: labelled email/password, keyboard submission, visible field error/global invalid-login message, loading/pending state, password never echoed; no role dropdown. Both role navigation and logout button. Refresh pending current-user check must not flash private content to anonymous

• Email format and length <=254; trim/lowercase for lookup. Password nonempty and <=128 characters; no trim/transformation. Seed passwords require >=12 characters; self-registration absent

• API methods/shapes/statuses exactly F-01 section of integration contract; no other routes here. Unknown keys rejected. Header names case-insensitive

• User passwordHash Argon2id; Session stores tokenHash, csrfToken, userId nullable, expiresAt. Pre-auth30min/auth8h fixed; issued from injectable server clock. Cookie policy and security parameters in SDS. Token hashing is only session-token storage, not password hashing

• Unsafe endpoints require valid Origin and synchronizer token; login included. Authenticated feature middleware applies auth->role->CSRF/payload->owner in documented order. GET auth endpoints no-store

• CSRF token/tokenHash/passwordHash excluded from generic user output/logs. `/auth/csrf` explicitly returns only CSRF token+expiry; cookie opaque identifier not JSON

## 3. Acceptance criteria

| ID | Observable expected result |
|---|---|
| AC-F01-01 | Valid login for each role returns corresponding safe identity and rotated authenticated cookie/token; stored password is a verifiable Argon2id hash |
| AC-F01-02 | Wrong password or unknown account gives same generic401 shape and no authenticated session; malformed/missing fields give documented validation |
| AC-F01-03 | `/auth/me` returns correct session identity after reload; absent, tampered or expired session gives401 without private fields |
| AC-F01-04 | Logout204 deletes/revokes current session, clears matching cookie, and replay of that token gives401; another independently logged-in session remains valid |
| AC-F01-05 | Anonymous protected request401 and wrong-role operation403; neither changes persistent domain data |
| AC-F01-06 | Mutating request missing/incorrect CSRF or wrong Origin is403 without mutation, including login; authenticated session cookie has intended HttpOnly/SameSite/Path/Secure attributes |
| AC-F01-07 | Login rotates pre-auth/existing session so old token no longer authenticates; expiry is fixed8h, checked server-side |
| AC-F01-08 | Login, logout, reload, error recovery and role navigation work in selected browser journey; credentials/tokens are not rendered/logged |

## 4. Software test specification

Results at contract authoring: NOT RUN. Current actual files/results/versions are mapped in the verification record. Proposed filenames below are the original plan, not execution evidence; some cases are consolidated into auth.test.ts/goals.test.ts

| Test ID | AC | Level / preconditions and action | Expected result | Planned file |
|---|---|---|---|---|
| TEST-F01-01 | 01 | DB integration; seed two roles with hashed fixture passwords; bootstrap then valid login | 200 safe user per role; session persisted; hash differs from plaintext and verifies | server/tests/integration /auth.test.ts |
| TEST-F01-02 | 02 | API+DB; unknown email and wrong password with valid CSRF; missing/oversize inputs | generic401 for credential failures;422 for field failure; no authenticated row | server/tests/integration /auth.test.ts |
| TEST-F01-03 | 03 | API+DB; valid cookie then no cookie/random cookie/clock advanced to expiry | valid identity200; other401 and no private fields | server/tests/integration /auth.test.ts |
| TEST-F01-04 | 04 | API+DB; create two sessions; logout first and replay both | first401; second200; revoked row absent; cookie cleared | server/tests/integration /auth.test.ts |
| TEST-F01-05 | 05 | Feature API+DB; anonymous create goal; Participant create template; Manager read goals | 401/403/403 respectively; before/after row counts unchanged | server/tests/integration /access.test.ts |
| TEST-F01-06 | 06 | API+DB; login/logout/domain POST with omitted/wrong token or wrong Origin | 403; no auth/domain mutation; no permissive CORS | server/tests/integration /csrf.test.ts |
| TEST-F01-07 | 06,07 | API+DB; inspect Set-Cookie in dev/prod config, login rotation and fixed clock | flags match config; old token invalid; now==expiresAt rejects | server/tests/integration /auth.test.ts |
| TEST-F01-08 | 08 | Browser; keyboard login, refresh, role nav, logout, invalid-login retry at desktop/mobile | correct screen/states; no identity switch UI; logged-out private content unavailable | e2e/auth.spec.ts |

TEST-F01-05 actual endpoints run after B/F-03 integration; middleware unit tests alone do not prove deployed access protection

### 5. TDD and definition of done

Use meaningful failing test first for server-side expiry/revocation or forbidden operation, preserve actual failing assertions/output/commit; implement; rerun green and regression. A dependency/config failure is not domain red evidence

Done only when implementation satisfies ACs, required meaningful tests executed with actual results, feature access cases integrated, B has reviewed real changes, docs/setup current, release integration complete and gaps disclosed. At the original contract date there was no execution evidence or completed peer integration. Current completed review, integration and results are recorded in Part F

## F-02 engineering contract

Contract content recorded before implementation. Current review/merge and actual execution are in Part F. Planned filenames in the historical STS may differ from consolidated actual filenames; stable TEST and AC IDs are retained.

### 1. Linked requirements / scope

Links: FR-04/05/06/19; BR-01/07/10; NFR-01/02/03/04/06/07/08. Extend the existing shared adapter/auth/schema; no second scaffold or migration. Template update/deactivate belongs to F-05; deletion is out of scope.

### 2. Feature SDS / UI / API / data

Manager login -> catalog -> create -> save DB -> fresh list/detail. Participant login -> active catalog/detail -> F-03 goal picker. Identity/role come from server session; use shared CSRF/Origin checks. Manager cannot read participant goals/entries.

• GET /api/templates?page=1&pageSize=20 and /api/templates/:templateId: participant active only; manager includeInactive=true permitted; sort createdAt DESC/id ASC; return data:TemplateDTO[] and meta:{page,pageSize,total}.

• POST /api/templates: PROGRAM_MANAGER only; {title,description?,minMinutes,maxMinutes}. Trim title1..100 Unicode code points, description<=500/default empty; JSON integer bounds1..1440 and min<=max. Equal titles may have different UUIDs.

• Server assigns unit=MINUTES, isActive=true, creator and timestamps; return201 with allowlisted TemplateDTO. Client id/unit/owner/role/status fields are unknown422.

• Errors: anonymous401, role/CSRF/Origin403, validation422, UUID syntax400, missing/invisible404, safe internal500. Field errors are string values plus requestId.

• UI /manager/templates/new has labels, helpers and field errors, preserves input after errors and disables inputs/submit while pending. Unknown POST outcome requires catalog inspection before manual retry; no automatic POST retry or exactly-once claim. Catalog has loading/empty/retry/create/inactive-filter states; participant has no create action.

• Reuse ActivityTemplate and existing constraints/migrations; validate in API and database. No schema change. F-03 rechecks active state and snapshots title/unit/range; F-02 never changes goal snapshots.

### 3. Acceptance criteria / STS

The following STS was planned at the contract commit. Manager/P1/P2 are synthetic accounts, separate from team members. Integration uses real isolated PostgreSQL; actual execution mapping is in Part F.

| AC | Observable outcome | Planned test IDs (level / preconditions, action -> expected) |
|---|---|---|
| AC-F02-01 | Manager create201, normalized allowlisted DTO, one persisted row owned by session | TEST-F02-01 API+DB: manager/CSRF -> POST trimmed/omitted description -> 201/default/server fields; TEST-F02-11 API+DB: deliberate same-title twice -> distinct IDs |
| AC-F02-02 | Invalid fields/ranges/types422/no writes; exact bounds accepted | TEST-F02-02 unit: parameterized 100/101 title,500/501 description,1/1440,min=max,reverse,noninteger; TEST-F02-03 API+DB: valid manager POST same invalid/boundary matrix -> expected counts |
| AC-F02-03 | Active/paged/detail/empty catalog, manager inactive only; safe DTO | TEST-F02-04 API+DB: mixed active/inactive fixtures and tie timestamps -> both roles list/detail/filter/pagination checks; wrong-role inactive403 |

| AC | Observable outcome | Planned test IDs (level / preconditions, action -> expected) |
|---|---|---|
| AC-F02-04 | Anonymous401 and Participant create403 even forged role, no mutation | TEST-F02-05 API+DB: anonymous/P1 -> GET/POST/spoof payload ->401/403 and DB unchanged |
| AC-F02-05 | CSRF/origin reject403; revoked session401 | TEST-F02-06 API+DB: manager -> bad token/origin, logout, replay cookie ->403/401; no writes |
| AC-F02-06 | Fresh API/new app instance/reload retrieve DB-backed result | TEST-F02-07 API+DB: saved template -> fresh GET/new app with same DB -> ID/content match; TEST-F02-10 browser: manager create -> reload -> Participant selection |
| AC-F02-07 | Unknown fields422; errors and DTO never leak DB/credentials/private records | TEST-F02-08 API+DB: unknown keys and isolated controlled DB insert failure ->422/safe500, no rows |
| AC-F02-08 | Loading/empty/validation/saving/error/unknown outcome recover visibly, keyboard usable | TEST-F02-09 browser: controlled delay/network/422 -> pending disabled, input preserved, no automatic retry, catalog inspection; viewport390x844/1440x900 |
| AC-F02-09 | Manager-created template can be selected by Participant to create own goal | TEST-F02-10 browser with real API/DB: login manager->create->logout->Participant->goal->reload; Participant cannot access manager create route |

### 4. DoD / execution evidence

Contract committed before tests/implementation; feature Issue and bounded branch; API red for missing manager POST/range rejection then green with real DB; unit/API/browser checks and build recorded with file/name/command/counts/result/source commit; A regression kept enabled. A reviews PR before accepted staging integration. B cannot approve A as its author. No accepted release until both features/full journey verified and peer review done. Keep failed/skipped counts and safe screenshots; no secrets

### 5. Revision decisions

| Version | Change / reason | Acceptance |
|---|---|---|
| draft01 | Original standalone B proposal in e3714d0 | Historical, superseded |
| 0.2 | Adopt A /api/templates, MINUTES, title100/description500, server-owned unit, pagination/DTO/error/CSRF/logout204; retain stable AC/test IDs | Implementation approved to begin; peer review pending at this contract version |

## F-03 engineering contract

Contract content recorded before implementation. Current review/merge and actual execution are in Part F. Planned filenames in the historical STS may differ from consolidated actual filenames; stable TEST and AC IDs are retained.

### 1. Workflow and dependencies

Participant selects active template, enters integer target minutes and today/tomorrow start date, submits and sees persisted personal goal. Own list/detail retrieve committed records from database. Manager cannot use goal endpoints; other participant cannot retrieve goal details

Requires F-01 principal/role/CSRF, F-02 active templates, shared clock/errors/DB. During development F-02 fixtures can support tests, but accepted end-to-end evidence must include real manager-created template. F-04 consumes goal snapshot and targetForDate service

### 2. UI specifications

• `/goals`: own goal cards/list, start date/current target/status, loading/empty/error states, create action. Empty state links to template selection

• `/goals/new`: loads active templates; selected title/range visible; target integer input; date picker today/tomorrow; submit pending state; field errors preserve entered values. Empty active catalog shows useful instruction

• `/goals/:goalId`: snapshot title/unit/bounds, start/status/target plus integration area for B's daily entry/progress. Future-start goal shows start date and disallows premature entry in UI/backend

• 409 duplicate links to own goals; inactive template requires refreshing available list;401 goes to login without auto replay;403/404 safe screen. No current-user/owner selector

• Keyboard labels/focus and 390x844/1440x900 supported; B and A agree shared route/component props before editing root router

## 3. API/data and business rules

POST/GET `/api/goals`, GET `/api/goals/:goalId` use exact shared shapes. No edit/delete endpoint in S1

Create payload `{templateId,dailyTargetMinutes,startDate}` only; owner from server. Validate template UUID, real date, integer range and today/tomorrow using server clock. Missing template404; inactive422; concurrent/serial ACTIVE duplicate409

In transaction: read/validate template; insert Goal with snapshot title/unit/min/max, owner, statusACTIVE; insert initial GoalTargetVersion at startDate; commit together. Partial unique index protects one ACTIVE goal per owner/template. Any initial version failure rolls back entire goal. User role/goal date constraints service-enforced, not assumed from FK alone

Own list constrained ownerId and supports page/pageSize/status; detail uses owner-scoped query. DTO excludes owner/user password/session data. List target for future-start goal uses initial version; own detail query does not expose another owner's record. Target service for F-04 queries requested date and never substitutes latest target for historical date

No template range mutation endpoint in S1. S2 lifecycle changes must preserve snapshot and lock ordering per revised contract; they are not implicitly implemented here

## 4. Acceptance criteria

| ID | Observable expected result |
|---|---|
| AC-F03-01 | Participant creates goal from active template with valid target/today-or-tomorrow date;201 returns goal and DB contains goal+initial target version owned by session user |
| AC-F03-02 | Own list/detail retrieve the saved goal after new request and application restart using same durable DB; empty list is valid200 |
| AC-F03-03 | Out-of-range/fractional target, invalid/past/day-after-tomorrow date and unknown fields rejected; no partial goal/version rows |
| AC-F03-04 | Missing/inactive template yields404/422 respectively and no goal created |
| AC-F03-05 | Serial and competing requests for same owner/template produce exactly one ACTIVE goal and one initial target; losers409; different participants may use same template |
| AC-F03-06 | Anonymous401, Manager403, other Participant detail404; lists contain only own goals; client-supplied ownerId cannot assign another owner |
| AC-F03-07 | Goal snapshot matches template at creation and initial target is effective on startDate; future-start goal DTO valid; target lookup before start rejects rather than using an unrelated version |
| AC-F03-08 | UI creation/list/detail, validation, empty/error/session states work at required viewports and integrate with B's template/entry boundaries |

## 5. Software test specification

At contract creation all results were NOT RUN. Planned filenames below remain the original design; actual cases consolidated into goals.test.ts/goal-rules.test.ts plus restart-smoke.ts/browser spec are mapped in the verification record

| Test ID | AC | Level / inputs and action | Expected result | Planned file |
|---|---|---|---|---|
| TEST-F03-01 | 01,07 | API+DB; participant cookie/CSRF; active template1..1440; target60,start=today and separate template tomorrow | 201; owner identity correct; snapshot+initial version consistent | server/tests/integration/goals.test.ts |
| TEST-F03-02 | 02 | API+DB; new client request, then restart API and relogin against same test DB | saved own record/list200; no row loss; seeded empty participant list200[] | server/tests/integration/goals.persistence.test.ts |
| TEST-F03-03 | 03 | unit+API; target0/1441/1.5; start past/+2/2026-02-30; missing/unknown fields; injected target-insert failure | documented400/422; transaction rollback leaves counts unchanged | server/tests/integration/goals.test.ts |
| TEST-F03-04 | 04 | API+DB; unknown UUID and inactive template | 404 and422; goal count unchanged | server/tests/integration/goals.test.ts |

| Test ID | AC | Level / inputs and action | Expected result | Planned file |
|---|---|---|---|---|
| TEST-F03-05 | 05 | API+DB; duplicate sequential then two simultaneous creates for fresh owner/template; second participant same template | one201 and one409 in race; one goal/version; second participant allowed | server/tests/integration/goals.concurrent.test.ts |
| TEST-F03-06 | 06 | API+DB; no session; manager; userB GET userA goal; userB list; payload ownerId | 401/403/404; list excludes A; unknown ownerId422 with no reassignment | server/tests/integration/goals.access.test.ts |
| TEST-F03-07 | 03,07 | unit+API fixed clock at 2026-11-03T16:59:59Z then17:00:00Z; leap/month/year cases | today switches 3->4 Nov in Bangkok; date validity/range deterministic; effective target selected for date | server/tests/unit/goal-rules.test.ts |
| TEST-F03-08 | 08 | browser full manager-template->participant-goal->retrieve journey plus empty/invalid/duplicate cases | visible persisted goal, meaningful errors and usable layouts | e2e/goals.spec.ts |

### 6. TDD and definition of done

Selected meaningful TDD case: duplicate ACTIVE goal rule with DB concurrency protection, or target/start-date boundary. Keep actual red/green versions/output. Migration failure/config error is not rule failure evidence

DoD: complete ACs with real DB/unit/E2E results as appropriate; B review with specific findings; integration to staging and reviewed release process; docs/traceability/setup updated; actual commit/commands/counts attached. Incomplete/failed/skipped cases remain explicit. At the original contract date, the complete manager-created-template/F04 journey and peer acceptance were future work. Their completed execution and review history are recorded in Part F

## F-04 engineering contract

Contract content recorded before implementation. Current review/merge and actual execution are in Part F. Planned filenames in the historical STS may differ from consolidated actual filenames; stable TEST and AC IDs are retained.

### 1. Linked requirements / boundary

SRS: FR-04/11/12/19; BR-01/02/04/05/06/07/08/10/11; NFR-01/02/03/04/05/06/07/08. Shared integration is authoritative for /api, UUID, DTO/envelope, CSRF and errors. No F05 revision/lifecycle API, F06 correction/delete/history UI, or new schema/migration in this feature

### 2. Feature SDS / API / data

Participant opens own goal -> picks valid Bangkok date -> POST minutes -> committed EntryDTO -> GET progress/reload from PostgreSQL. Manager403; other/missing goal404 identical shape; principal owner only. Strict payload before owner lookup as existing A middleware; domain checks after owner. Use requireOwnedGoal/targetForDate/shared clock, existing DailyEntry UNIQUE(goalId,entryDate), Goal snapshots and target versions. Goal reader parameter types may be narrowed to accept transaction client, without changing A behavior

| Method | Input | Success |
|---|---|---|
| POST `/api/goals/:goalId/entries` | `{entryDate,minutes}` + session/CSRF/Origin | 201 `{data:EntryDTO}` including server targetMinutes/progressPercent/achieved |
| GET `/api/goals/:goalId/entries?page=1&pageSize=20` | bounded pagination, own goal | 200 `{data:EntryDTO[],meta:{page,pageSize,total}}`, entryDate DESC/id ASC |
| GET `/api/goals/:goalId/progress?date=YYYY-MM-DD` | required date, own goal | 200 `{data:{goalId,date,actualMinutes,targetMinutes,progressPercent,achieved,entryId}}` |

• Date is real YYYY-MM-DD; syntax400 INVALID_DATE, impossible/out-of-bounds422 with correct entryDate/date field. Allowed startDate..min(todayBangkok,endDate if set), inclusive; GET uses same date bounds. S1 goals ACTIVE normally; archived fixture may record historical dates within endDate per A BR11, no archive endpoint added

• JSON integer minutes within immutable goal snapshot range1..1440; no 0/fraction/string/boolean/null. Unknown keys including client owner/unit/target/version/progress/id/timestamps422

• Progress = actual/target*100; integer-ratio HALF_UP to 2 decimals; no cap. achieved uses actual>=target before rounding. Target resolved by entry date (including old effective version), never current goal target. Missing entry has actual0/progress0/achievedfalse/entryIdnull without row creation

• Duplicate sequential/concurrent ->409 ENTRY_ALREADY_EXISTS; one winner201, exactly one stored row, never overwrite/upsert. Transaction locks owned goal row FOR SHARE, rechecks bounds and inserts; handle database unique error safely. Future lifecycle writers must use compatible lock order

• Errors use A fields:string/requestId;401/403/404/400/422/409/500; no data leakage, rollback on errors. Target missing is domain422, no success with default target

### 3. UI

Use GoalDetail ActivityComponent slot in existing route with props `{goal,onSessionExpired?}`. Date label, integer minute range, actual/target, unbounded percentage and achieved; bar may visually cap100 but label never caps. Future start shows notice/no invalid fetch. Loading/empty distinctly rendered; date changes discard stale responses; inputs/submit disabled while saving. Saved day disables new entry. Duplicate or unknown POST outcome GETs original date before manual retry, never auto-POST; if reconciliation GET fails block resubmit until successful read. Input remains on errors;401 clears private view through shared auth; no role selector. Usable at390x844 and1440x900 with labels/keyboard/field errors

### 4. Acceptance criteria / STS

All STS planned at contract version; real API+PostgreSQL fixtures Manager/P1/P2; injected Bangkok clock; each actual test name/result/commit later added to traceability

| AC | Expected observable outcome | Planned tests (level / preconditions, action -> expected) |
|---|---|---|
| AC-F04-01 | Own valid entry201, exactly one persisted row with authoritative target/calculation | TEST-F04-01 API+DB: P1 goal60/day ->POST45->GET/DB match75% |
| AC-F04-02 | Fresh app/GET/reload returns same entry; no entry returns null identity/zero without mutation; list paged | TEST-F04-01/02 API+DB: existing/empty owned days->read/list/new app->same record or entryIdnull; TEST-F04-16 browser reload |
| AC-F04-03 | 45/60=75,75/60=125,60/60=100,1/32=3.13; achieved exact | TEST-F04-03 unit ratio/boundaries; TEST-F04-04 API+DB: distinct fixtures->write/read->same percentages |
| AC-F04-04 | Date syntax400/calendar/range422; start/today included; Bangkok midnight/month/year correct | TEST-F04-05 unit fixed clock/date matrix; TEST-F04-06 API+DB before-start/future/impossible/missing query and valid endpoints->statuses/counts |
| AC-F04-05 | Snapshot range/min/max/integer only; invalid422 and no writes | TEST-F04-07 unit30..120 and1..1440; TEST-F04-08 API+DB parameterized invalid/boundary values |
| AC-F04-06 | Duplicate409/no overwrite; another own goal can record same date | TEST-F04-09 API+DB: original45->repeat75 plusP2 own goal->one unchanged row and valid other row |
| AC-F04-07 | Simultaneous requests yield one201/rest409 with exactly one stored row | TEST-F04-10 real API+DB: concurrent45/75 requests to same goal/date->status multiset/DB count/value |
| AC-F04-08 | Anonymous/revoked401,manager403,other/absent404; no private data/write | TEST-F04-11 API+DB: all GETlist/GETprogress/POST routes with role/owner fixtures; TEST-F04-12 logout replay |
| AC-F04-09 | Bad CSRF/origin403,unknown422, safe errors/DTO allowlist | TEST-F04-12/13 API+DB: invalid tokens, all injected fields, isolated failing DB trigger->no write/safe500 |
| AC-F04-10 | Initial/effective target and goal range snapshots govern history; archived date bounds respected | TEST-F04-14 API+DB: template changed/future target added/archived endDate->correct historical values and rejection afterendDate |
| AC-F04-11 | UI states/reconcile/date race/125%/session expiry work without duplicate POST | TEST-F04-15 browser: pending/delayed/aborted requests/409/422/5xx/401->state/input/recovery/viewport assertions |
| AC-F04-12 | Real manager-create->participant-goal->entry45->persisted75%->rejection/logout journey | TEST-F04-16 browser + realAPI/DB at both viewports; duplicate/future/cross-user/manager/revoked restrictions |

### 5. DoD / evidence

Commit contract/test design before implementation. Meaningful API red for missing entry/progress/concurrent behavior, then green; preserve versions/commands/counts/assertions. Run unit/API+DB/concurrency and selected UI journey/build plus A regression; separate guarded B DB, no dev/A DB resets. Map every AC to actual test names/result/source SHA. A review and staging integration/release still required; no invented PASS/PR/review/UAT/cloud evidence

### 6. Revision decisions

| Version | Change / rationale | Acceptance |
|---|---|---|
| draft01 | Standalone B interfaces e3714d0 | Historical |
| 0.2 | Align A /api, EntryDTO, paginated list/progress entryId, startDate/UUID, codes and field shape; BR11 archived historical bounds replace old B active-only proposal; HALF_UP specified | Implementation approved to begin; peer review pending at this contract version |

## E5. Product Definition of Done

All required behavior and important negative/boundary/role cases are implemented. Planned meaningful unit/API/PostgreSQL/browser verification is actually executed; failures/skips and limits are explicit. ACs map to real test IDs/files/names/results/source. Contracts precede code with visible justified revisions; intended-behavior red/green is retained. The teammate inspects changes and assertions, fixes are re-reviewed, features integrate into staging and the reviewed release reaches main. Setup/docs/evidence are current and both members can explain sampled design/tests/behavior. Main release completion is demonstrated by the actual reviewed merge and clean-main results in Part F; these checks do not certify later-sprint/cloud/UAT work.

# Part F. Working Sprint 1 and verification

## F1. Version and execution scope

Accepted main source: df08ec19cdeb0efcfbfbee92f3d385d87059528c; immutable tag: v0.1.0-sprint1. The primary API/unit, browser, build and restart outputs below were run on a clean detached checkout of this exact main commit. Fresh-install/seed and scripted screenshots were produced on85f510f; git comparison confirms identical application, tests, package and runtime configuration through accepted main. This is the explicit version exception for that demonstration/setup set. Report utility changes do not alter the product. Full-suite checks are automated; screenshot inspection is visual review, not independent human UAT.

Fresh checkout: npm ci installed229 packages/audited230 with0 vulnerabilities. Generated private environment files; migrated newly created, isolated D1 development and test databases; ran seed twice with unchanged3 users/2 templates. Alternate UI/API3400/5400 avoids occupied defaults. DB instance uses loopback25433 with different database names studytrack_d1_dev_20261104 and studytrack_d1_test_20261104. Original development/test databases were not reset.

| Command | Actual result |
|---|---|
| npm test | 117 passed / 0 failed / 0 skipped; 8 test files |
| npx playwright test --config playwright.member-b.config.ts | 24 passed / 0 failed / 0 skipped; desktop+mobile |
| npm run build | PASS: server/client typecheck and Vite production output |
| npx tsx scripts/member-b-restart.ts | PASS: actual API process restart and persisted45/60=75% |
| npm ci; migrate; seed twice | PASS:229 installed;0 vulnerabilities;3 users/2 templates after rerun |

Actual output excerpt: api-output.txt

```
 Test Files  8 passed (8)
      Tests  117 passed (117)
   Start at  15:32:27
   Duration  18.24s (tests 81%, import 15%, transform 3%, setup 1%)
```

Actual output excerpt: browser-output.txt

```
Running 24 tests using 1 worker
  ok  4 [desktop] › e2e\member-a.spec.ts:115:1 › FR-19: a failed list request offers retry and recovers with
    real API data (1.2s)
  ok 16 [mobile] › e2e\member-a.spec.ts:115:1 › FR-19: a failed list request offers retry and recovers with real
     API data (1.1s)
  24 passed (51.0s)
```

Actual output excerpt: build-output.txt

```
> npm run build:server && npm run build:client
> studytrack@0.1.0 build:server
> tsc -p server/tsconfig.json
> studytrack@0.1.0 build:client
> tsc -p client/tsconfig.json && vite build
  34 modules transformed.
  built in 404ms
```

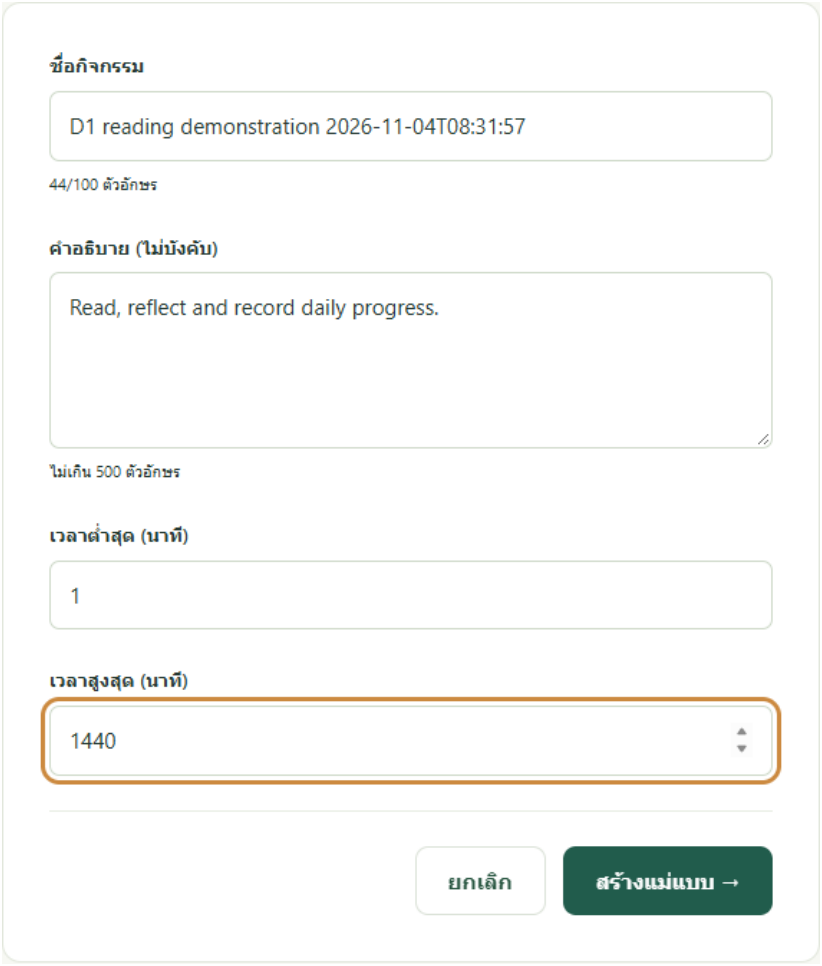
Actual output excerpt: restart-output.txt

```
PASS TEST-F02-07 / TEST-F04-01/02 / NFR-03: real API process stopped and restarted; DB sessions, manager-created
     template, goal, daily entry and 45/60=75% persisted.
```

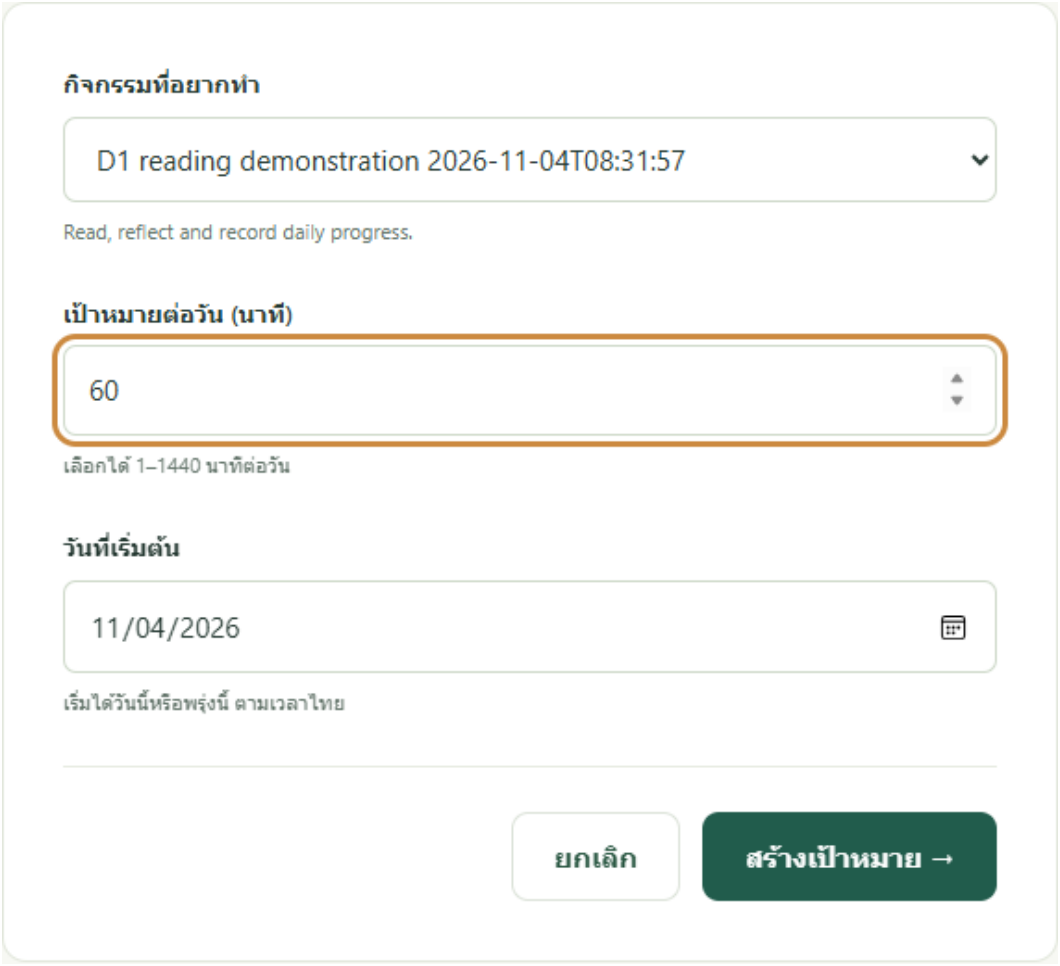
## F2. Program demonstrations

The following are real local UI/API/PostgreSQL scripted checks on the named application source. Synthetic manager/student1/student2 roles are distinct from team identities. Safe response dumps retain status/domain values only, without credentials/tokens. Each screenshot caption states role, starting conditions, action and expected/actual outcome. Refer to the single source reference above for this entire demonstration set.

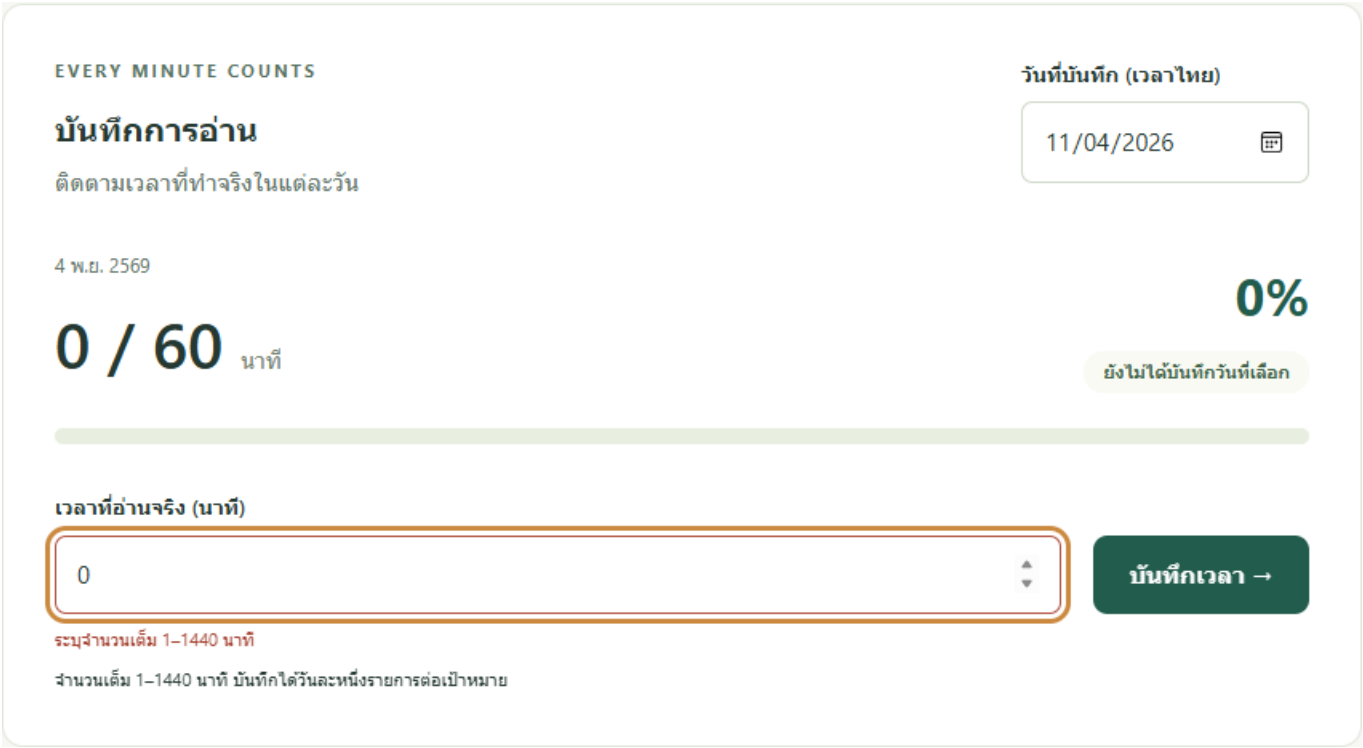
SC-01 / AC-F02-01/09: Manager, logged in; enter a reading template/range and save. Expected201 and persistent catalog item. Actual scripted flow created the template, then participant selected that same ID.



SC-02 / AC-F03-01/08: Participant/student1 selects the manager-created template, target60 and Bangkok today. Expected201 with own goal+initial target. Actual persisted goal created.



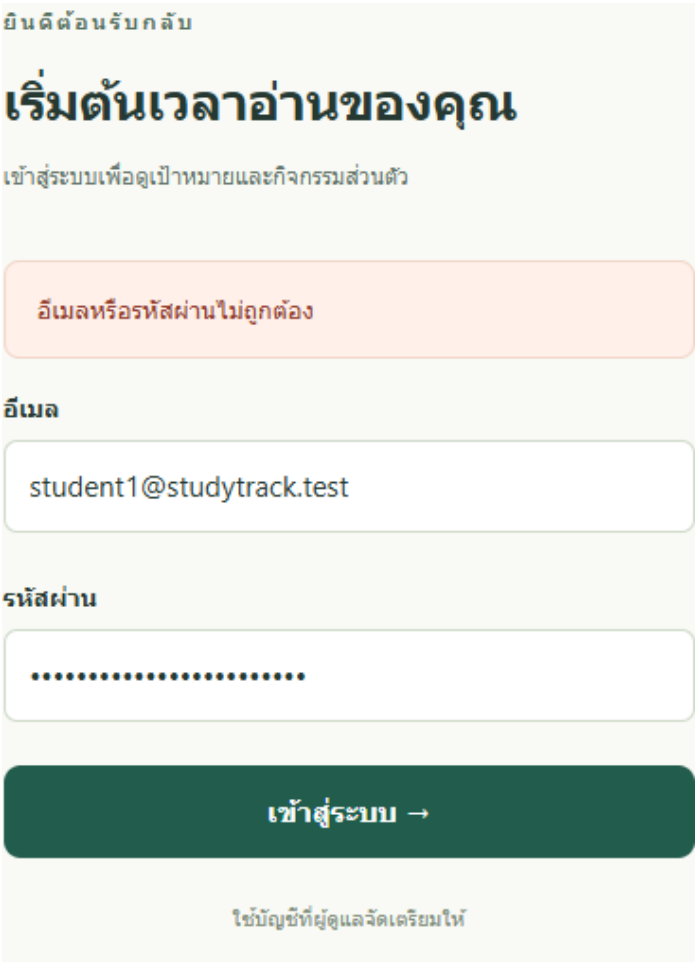

SC-03 / AC-F04-05/11: Participant has own valid goal; enter0 minutes and submit. Expected visible bounds error with no accepted activity. Actual form rejected; later valid45-minute write succeeded.



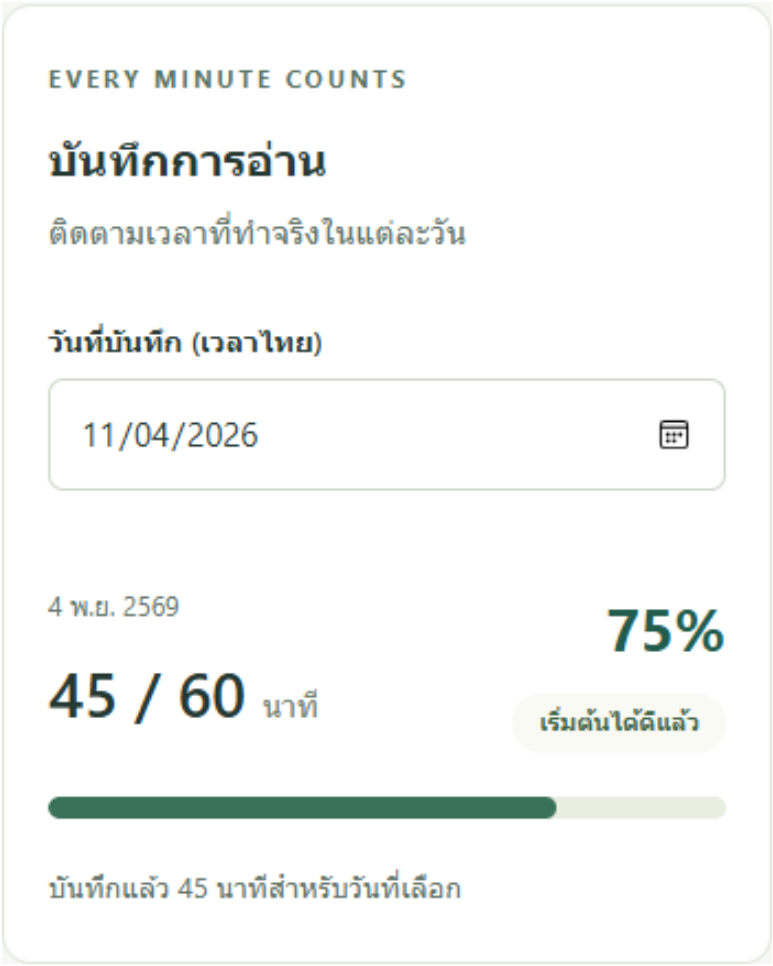
SC-04 / AC-F04-01/02/12: Participant records45 toward60, reloads. Expected saved45/60 and75%, same entry identity. Actual persisted API/DB retrieval matched; screenshot shows retrieved result.




SC-05 / AC-F01-02/08: Anonymous submits synthetic wrong credentials. Expected generic rejection and no authenticated view. Actual invalid-login error visible.



SC-06 / NFR-06 / AC-F04-11: Same participant opens saved goal at390x844. Expected readable, no horizontal overflow, saved75%. Actual screenshot and geometry check passed.



### Safe API/database screen dumps - expected and actual

| Scenario / role | Expected | Actual |
|---|---|---|
| Invalid synthetic login leaves protected identity unavailable | 401 | 401 |
| Manager creates persisted template | 201 | 201 |
| Manager logout revokes protected access | 401 | 401 |
| Participant creates own goal from manager-created template | 201 | 201 |
| Invalid zero minutes leaves database without an entry | 0 | 0 |
| Participant records valid45 minutes | 201 | 201 |
| Reload/API retrieval preserves45/60=75% and same entry | {'actualMinutes': 45, 'targetMinutes': 60, 'progressPercent': 75, 'entryId': '77a0ca0f-95c3-452d-84ef-6ea179f47a83'} | {'actualMinutes': 45, 'targetMinutes': 60, 'progressPercent': 75, 'entryId': '77a0ca0f-95c3-452d-84ef-6ea179f47a83'} |
| Duplicate entry rejects | 409 | 409 |
| Duplicate rejection code | ENTRY_ALREADY_EXISTS | ENTRY_ALREADY_EXISTS |
| Duplicate preserves first stored value and one row | {'minutes': 45, 'rows': 1} | {'minutes': 45, 'rows': 1} |
| Participant at manager create API | 403 | 403 |
| Mobile390 viewport has no horizontal overflow | True | True |
| Participant logout protected API | 401 | 401 |
| Other participant cannot read saved goal | 404 | 404 |
| Manager cannot read participant entries | 403 | 403 |

Sanitized retrieval response (no cookies or CSRF values)


```
{
  "goalId": "81e76991-79ac-47c8-a2b6-54796ff30c21",
  "date": "2026-11-04",
  "actualMinutes": 45,
  "targetMinutes": 60,
  "progressPercent": 75,
  "achieved": false,
  "entryId": "77a0ca0f-95c3-452d-84ef-6ea179f47a83"
}
```


## F3. Complete AC-to-actual-test result mapping

Each of the37 Sprint1 ACs below retains its contract TEST IDs, concrete actual file/name and PASS result from the recorded suites. Combined names consolidate planned split files; the mapping is not a claim that historical planned filenames all exist. Unit/API rows were exercised in the117-check run; browser rows in the24-check run. Restart supplements persistence. Full parameterized names and reports remain in the repository.

## F01 acceptance results

| AC / result | Planned TEST IDs | Actual test name / file |
|---|---|---|
| AC-F01-01 / PASS | TEST-F01-01 | F-01 real PostgreSQL sessions TEST-F01-01: salted Argon2id passwords and valid role identity; file(s): server/tests/integration/auth.test.ts |
| AC-F01-02 / PASS | TEST-F01-02 | F-01 real PostgreSQL sessions TEST-F01-02: wrong email/password share a generic failure and create no authenticated session; file(s): server/tests/integration/auth.test.ts |
| AC-F01-03 / PASS | TEST-F01-03 | F-01 real PostgreSQL sessions TEST-F01-03: absent/tampered and server-expired sessions return no private data; file(s): server/tests/integration/auth.test.ts |
| AC-F01-04 / PASS | TEST-F01-04 | F-01 real PostgreSQL sessions TEST-F01-04: logout revokes the real DB session, replay fails, independent session survives; file(s): server/tests/integration/auth.test.ts |
| AC-F01-05 / PASS | TEST-F01-05 / TEST-F03-06; TEST-F02-05/06 | F-03 persisted personal goals and backend permissions TEST-F01-05 / TEST-F03-06: role checks, ownership and collections are enforced on the real API; file(s): server/tests/integration/goals.test.ts, server/tests/integration/templates.test.ts |
| AC-F01-06 / PASS | TEST-F01-06; TEST-F02-05/06; TEST-F04-12 | F-01 real PostgreSQL sessions TEST-F01-06: login CSRF/origin failures do not authenticate; file(s): server/tests/integration/auth.test.ts, server/tests/integration/entries.test.ts, server/tests/integration/goals.test.ts, server/tests/integration/templates.test.ts |
| AC-F01-07 / PASS | TEST-F01-07 | F-01 real PostgreSQL sessions TEST-F01-07: rotating login removes old pre-auth token and fixes the 8h expiry; file(s): server/tests/integration/auth.test.ts |
| AC-F01-08 / PASS | TEST-F01-08 | TEST-F01-08: invalid login, keyboard recovery, reload and logout revoke browser access; file(s): member-a.spec.ts |

## F02 acceptance results

| AC / result | Planned TEST IDs | Actual test name / file |
|---|---|---|
| AC-F02-01 / PASS | TEST-F02-01/07 | F-02 manager templates, persistence and access TEST-F02-01/07: manager creates normalized template and a fresh app reads the committed row; file(s): server/tests/integration/templates.test.ts |
| AC-F02-02 / PASS | TEST-F02-02/03 | TEST-F02-02: template validation boundaries normalizes whitespace, defaults description, and counts Unicode code points; file(s): server/tests/unit/template-rules.test.ts |
| AC-F02-03 / PASS | TEST-F02-04 | F-02 manager templates, persistence and access TEST-F02-04: active catalog/detail are paginated and inactive templates remain manager-only; file(s): server/tests/integration/templates.test.ts |
| AC-F02-04 / PASS | TEST-F02-05/06 | F-02 manager templates, persistence and access TEST-F02-05/06: roles, CSRF/origin and revoked cookies are enforced before writes; file(s): server/tests/integration/templates.test.ts |
| AC-F02-05 / PASS | TEST-F02-05/06 | F-02 manager templates, persistence and access TEST-F02-05/06: roles, CSRF/origin and revoked cookies are enforced before writes; file(s): server/tests/integration/templates.test.ts |
| AC-F02-06 / PASS | TEST-F02-01/07; TEST-F02-10 | F-02 manager templates, persistence and access TEST-F02-01/07: manager creates normalized template and a fresh app reads the committed row; file(s): member-b.spec.ts, server/tests/integration/templates.test.ts |
| AC-F02-07 / PASS | TEST-F02-08 | F-02 manager templates, persistence and access TEST-F02-08: server-owned fields are rejected; failed database insert produces only safe errors; file(s): server/tests/integration/templates.test.ts |
| AC-F02-08 / PASS | TEST-F02-09 | TEST-F02-09: validation, pending and unknown POST outcome preserve input without automatic retry; file(s): member-b.spec.ts |
| AC-F02-09 / PASS | TEST-F02-10 | TEST-F02-10: real manager creation -> persisted catalog -> participant goal selection; file(s): member-b.spec.ts |

## F03 acceptance results

| AC / result | Planned TEST IDs | Actual test name / file |
|---|---|---|
| AC-F03-01 / PASS | TEST-F03-01 | F-03 persisted personal goals and backend permissions TEST-F03-01/07: creates goal and initial version atomically with immutable snapshots; file(s): server/tests/integration/goals.test.ts |
| AC-F03-02 / PASS | TEST-F03-02; restart | F-03 persisted personal goals and backend permissions TEST-F03-02: reload and new application instance retrieve committed data; file(s): server/tests/integration/goals.test.ts |
| AC-F03-03 / PASS | TEST-F03-03 | F-03 persisted personal goals and backend permissions TEST-F03-03: rejects invalid target 0 without partial records; file(s): server/tests/integration/goals.test.ts |
| AC-F03-04 / PASS | TEST-F03-04 | F-03 persisted personal goals and backend permissions TEST-F03-04: missing and inactive templates create no goal; file(s): server/tests/integration/goals.test.ts |
| AC-F03-05 / PASS | TEST-F03-05 | F-03 persisted personal goals and backend permissions TEST-F03-05: simultaneous requests store one ACTIVE goal and one target version; file(s): server/tests/integration/goals.test.ts |
| AC-F03-06 / PASS | TEST-F03-06 | F-03 persisted personal goals and backend permissions TEST-F01-05 / TEST-F03-06: role checks, ownership and collections are enforced on the real API; file(s): server/tests/integration/goals.test.ts |
| AC-F03-07 / PASS | TEST-F03-07; TEST-F04-14 | F-04 persisted daily entries, date-effective progress and privacy TEST-F04-14: effective targets and immutable snapshot ranges preserve historical progress; file(s): server/tests/integration/entries.test.ts, server/tests/integration/goals.test.ts, server/tests/unit/goal-rules.test.ts |
| AC-F03-08 / PASS | TEST-F03-08; TEST-F02-10; TEST-F04-16 | TEST-F03-08: create, reload and retrieve a real persisted goal; duplicate is rejected; file(s): member-a.spec.ts, member-b.spec.ts |

### F04 acceptance results

| AC / result | Planned TEST IDs | Actual test name / file |
|---|---|---|
| AC-F04-01 / PASS | TEST-F04-01/02 | F-04 persisted daily entries, date-effective progress and privacy TEST-F04-01/02: committed entry and progress survive a fresh request/app; empty day has no phantom row; file(s): server/tests/integration/entries.test.ts |
| AC-F04-02 / PASS | TEST-F04-01/02; TEST-F04-16 | F-04 persisted daily entries, date-effective progress and privacy TEST-F04-01/02: committed entry and progress survive a fresh request/app; empty day has no phantom row; file(s): member-b.spec.ts, server/tests/integration/entries.test.ts |
| AC-F04-03 / PASS | TEST-F04-03/04 | F-04 daily rules TEST-F04-03: 45/60 gives 75 percent with achieved=false; file(s): server/tests/unit/entry-rules.test.ts |
| AC-F04-04 / PASS | TEST-F04-05/06 | F-04 daily rules TEST-F04-05: calendar validation includes leap/month/year transitions and correct field names; file(s): server/tests/unit/entry-rules.test.ts |
| AC-F04-05 / PASS | TEST-F04-07/08 | F-04 daily rules TEST-F04-07: invalid minutes 29 reject without coercion; file(s): server/tests/unit/entry-rules.test.ts |
| AC-F04-06 / PASS | TEST-F04-09 | F-04 persisted daily entries, date-effective progress and privacy TEST-F04-09: serial duplicate never overwrites and another participant can record the same day; file(s): server/tests/integration/entries.test.ts |
| AC-F04-07 / PASS | TEST-F04-10 | F-04 persisted daily entries, date-effective progress and privacy TEST-F04-10: competing API writes get one201/one409 backed by exactly one database row; file(s): server/tests/integration/entries.test.ts |
| AC-F04-08 / PASS | TEST-F04-11/12 | F-04 persisted daily entries, date-effective progress and privacy TEST-F04-11: all entry/progress routes reject anonymous/manager/cross-owner without revealing private data; file(s): server/tests/integration/entries.test.ts |
| AC-F04-09 / PASS | TEST-F04-12/13 | F-04 persisted daily entries, date-effective progress and privacy TEST-F04-12: bad CSRF/origin and logout replay cannot write or retrieve protected entries; file(s): server/tests/integration/entries.test.ts |
| AC-F04-10 / PASS | TEST-F04-14 | F-04 persisted daily entries, date-effective progress and privacy TEST-F04-14: effective targets and immutable snapshot ranges preserve historical progress; file(s): server/tests/integration/entries.test.ts |
| AC-F04-11 / PASS | TEST-F04-15 | TEST-F04-15: validation and committed-but-lost response reconcile before any retry; file(s): member-b.spec.ts |
| AC-F04-12 / PASS | TEST-F04-16 | TEST-F04-16: full manager -> goal -> daily entry -> persisted progress with rejection, privacy and logout; file(s): member-b.spec.ts |

## F4. Two actual test excerpts

These selected unchanged excerpts include setup and assertions from actual automated sources, not pseudocode. Both tests passed in the117-check result. Sensitive headers refer only to synthetic in-memory fixtures; no token values are printed.

### Domain invariant: two competing writes, exactly one row (TEST-F04-10)

```
it("TEST-F04-10: competing API writes get one201/one409 backed by exactly one database row", async () => {
  const session = await login();
  const own = await goal(session);
  const results = await Promise.all([
    post(session, own.id, 45),
    post(session, own.id, 75),
  ]);
  expect(results.map((r) => r.status).sort()).toEqual([201, 409]);
  expect(results.find((r) => r.status === 409)!.body.error.code).toBe(
    "ENTRY_ALREADY_EXISTS",
  );
  const winner = results.find((r) => r.status === 201)!.body.data;
  const rows = await db.dailyEntry.findMany({ where: { goalId: own.id } });
  expect(rows).toHaveLength(1);
  expect(rows[0].minutes).toBe(winner.minutes);
  expect(rows[0].id).toBe(winner.id);
});
```

### Role/ownership: anonymous and cross-owner rejection (TEST-F01-05 / TEST-F03-06; selected beginning)

```
it("TEST-F01-05 / TEST-F03-06: role checks, ownership and collections are enforced on the real API", async ()
  => {
  await request(app).get("/api/goals").expect(401);
  await request(app).post("/api/goals").send(body()).expect(401);
  const session = await login();
  const created = await session.agent
    .post("/api/goals")
    .set("Origin", origin)
    .set("X-CSRF-Token", session.csrf)
    .send(body())
    .expect(201);
  const other = await login("b@studytrack.test");
  const forbidden = await other.agent
    .get(`/api/goals/${created.body.data.id}`)
    .expect(404);
  const missing = await other.agent
    .get("/api/goals/99999999-9999-4999-8999-999999999999")
    .expect(404);
  expect(forbidden.body.error.code).toBe(missing.body.error.code);
  expect(forbidden.body.error.message).toBe(missing.body.error.message);
  expect(JSON.stringify(forbidden.body)).not.toContain("Read CPE 334");
  const ownList = await other.agent.get("/api/goals").expect(200);
  expect(ownList.body.data).toEqual([]);
  expect(ownList.body.meta.total).toBe(0);
```

## F5. Meaningful TDD and correction history

Contract baseline11cdfe5 preceded application implementation. Red2fc6252 ran6 checks:3 passed/3 failed (logout/rule assertions failed against unimplemented behavior, with real login/PostgreSQL fixture working). Greena13858f reran the same6:6passed/0failed/0skipped. Expanded checks were added without treating an environment failure as domain TDD.

Actual retained red2fc6252 and initial greena13858f output

```
     ->  expected 204 "No Content", got 501 "Not Implemented"
     ->  expected [Function] to not throw an error but 'Error: Goal rules are not implemented...' was thrown
 Error: expected 204 "No Content", got 501 "Not Implemented"
 AssertionError: expected [Function] to not throw an error but 'Error: Goal rules are not implemented...' was
     thrown
 "Error: Goal rules are not implemented yet."
 -   "status": 422,
 +   "message": "Goal rules are not implemented yet.",
 +   "status": 501,
  Test Files  2 failed (2)
       Tests  3 failed | 3 passed (6)
 --- GREEN a13858f ---
  Test Files  2 passed (2)
       Tests  6 passed (6)
    Duration  2.10s (import 45%, tests 42%, transform 10%, setup 2%, worker 1%)
```

B F02 contractee14477 preceded red0e1ca17 (15fail/1pass) and greena3769d4; B F04 red d709741 had30fail against missing routes before implementation. Final integrated code passes all117/24. Historical fixture-clock/session and browser logout-timing failures are retained in author evidence; they were corrected without removing expiry/logout assertions. PR3 review found localhost case/root-dot guard bypass: review-red db199eb had2fail/7pass, fixd2efada had9guardpass plus full40 API/10browser at that revision. Current117 includes the corrected guard. These historical failed counts are disclosed separately from current full-suite0fail/0skip.

## F6. Engineering workflow, review and contribution

| PR / feature | Branch chain | Actual review / integration |
|---|---|---|
| #3 Add member A authentication and personal reading goals | codex/member-a-sprint1 -> codex/sprint-1-staging | Datakung: CHANGES_REQUESTED on 2370df9; Datakung: APPROVED on 94156cf; MERGED; merge 1a4b74b83739 |
| #6 Add manager-created activity templates and persisted catalog | codex/f02-templates -> codex/sprint-1-staging | auto4496: APPROVED on ec681e9; MERGED; merge 18e58829d917 |
| #7 Record daily reading and retrieve date-effective progress | codex/f04-entries-progress -> codex/sprint-1-staging | auto4496: APPROVED on 36fc9b6; MERGED; merge 85f510f0d73b |
| #8 docs: record accepted Sprint1 features and release readiness | codex/sprint-1-release-handoff -> codex/sprint-1-staging | auto4496: APPROVED on d9889e7; MERGED; merge 0c0915e2f7f0 |
| #9 Sprint 1 release candidate: auth, templates, goals and daily progress | codex/sprint-1-staging -> main | auto4496: APPROVED on 0c0915e; MERGED; merge df08ec19cdeb |

Actual review excerpt, PR3, Datakung, CHANGES_REQUESTED: Codex-assisted review requested by member B, pinned to 2370df9d760862a2c96aead7c70eb63762bb7192. Independently checked this PR in a separate checkout (without B feature changes): 38 API/unit tests and 10 desktop/mobile browser cases pass, production build passes, and the real API restart check passes. Reviewed session hashing/rotation/expiry/logout, CSRF/Origin, role/ownership, atomic goal+target creation, snapshots, date rules, unique protection and the pre-code/red/green history. Requesting one correction before foundation acceptance: the test database isolation guard accepts equivalent localhost spellings. Two new guard regression cases fail, and read-only PostgreSQL queries confirm both aliases reach the same isolated database. Details are attached to scripts/test-env.mjs. The reproduction did not delete or modify data; normal suites used only the dedicated B test database. The configured development database was not touched. PRs #6 and #7 remain draft and dependent on this PR. After the guard correction, rerun the new cases and a

Actual review excerpt, PR3, Datakung, APPROVED: Re-review of commit 94156cf230d9de0783170047078d6cdcd539524f following the P2 finding on 2370df9. The requested correction is complete: normalizedHost lowercases the hostname and removes its trailing DNS root dot before mapping loopback aliases. The comparison applies this normalization to both database URLs. LOCALHOST and localhost. are now included in the regression suite. I reviewed the full correction delta; the executable changes are confined to the guard and its tests. Independent verification on this exact head on 3 November: the submitted guard suite passed 9/9, and my two previously failing alias regression probes both passed. The head remains unchanged at this re-review. The original independent 38 API/unit checks, 10 browser checks, build and restart checks were on 2370df9 and remain historical results, not new full-suite runs on the correction. I also inspected A's correction evidence: 7-pass/2-fail red, 9-pass green, 40 API/unit passes, 10 browser passes, build and process-restart passes, anchored to d2efada. Those correc

Actual review excerpt, PR6, auto4496, APPROVED: ## Review outcome No blocking defects identified in the reviewed F02 changes at `ec681e9c93e9baff10879c1564957e5221d7605d`. Approved for integration into `codex/sprint-1-staging`. ## Scope inspected - Contract and AC alignment, actual diff and assertions. - Manager-only template creation; strict Unicode/title/description/range validation; server-owned creator, unit and status. - Session/role/CSRF/origin enforcement and participant catalog-to-goal integration. - UI pending, validation, read recovery and unknown POST outcome without automatic write retries. - Existing A regressions retained; no package, schema, migration or auth implementation changes. ## Independent reviewer verification Executed on an exported snapshot of this exact head with existing installed dependencies and guarded PostgreSQL test database, separate from development: | Check | Actual result | |---|---| | API/unit suite | 66 passed, 0 failed, 0 skipped | | Desktop/mobile browser suite | 16 passed, 0 failed, 0 skipped | | Production build | PASS | Commands: `npm tes

Actual review excerpt, PR7, auto4496, APPROVED: ## Review outcome No blocking defects identified. Approved for integration into `codex/sprint-1-staging` at `36fc9b69a26ba714e818febfd555ae033277024f`. PR6 has already been accepted and merged. ## Scope inspected Reviewed the F04 contract/AC, actual diff and assertions, owner/role/CSRF/origin guards, strict payload and Bangkok date validation, immutable bounds, historical target selection, transaction/row locks and concurrent duplicate handling, uncapped HALF_UP progress, paged reads and the GoalDetail integration. Inspected stale-read protection, lost-write-response reconciliation, error recovery and session clearing. ## Independent reviewer execution | Check | Actual result | |---|---| | API/unit | 117 passed, 0 failed, 0 skipped | | Desktop/mobile browser | 24 passed, 0 failed, 0 skipped | | Production build | PASS | | Actual API process restart | PASS: session, manager-created template, goal, entry and 45/60=75% persisted | Executed on merged candidate `f1577ea`, after incorporating accepted staging `18e5882`. That merge changed n

Actual review excerpt, PR9, auto4496, APPROVED: ## Release review Approved for main at 0c0915e2f7f0e7587c029e451ddc788413243030. PR8 is now reviewed/merged and this final release head includes that handoff. Inspected the staging-to-main scope and the accepted F01/F03 and F02/F04 contract, implementation, assertions and peer-review chain. The Sprint1 journey is manager template -> participant goal -> daily entry -> retrieved persisted progress, with real authentication/logout, role/ownership and domain/concurrency enforcement. No blocking finding remains. ## Actual verification A independently performed fresh npm ci (229 packages installed, audit0), generated private configuration, migrated new isolated PostgreSQL dev/test databases and seeded twice (3 users/2 templates). Application source85f510f passed117 API/unit and24 desktop/mobile browser checks with0 failures/skips, production build and actual API process-restart persistence. A further15 scripted local UI/API/database demonstration checks passed, including invalid login, zero-minute rejection,45/60=75%,409 duplicate preservin

Actual contract/TDD chronology (selected git log)

```
11cdfe5 2026-11-03T14:38:13+07:00 docs: record StudyTrack pre-implementation baseline
```

```
2fc6252 2026-11-03T15:11:13+07:00 test: add member A scaffold and failing logout and goal-rule specifications
a13858f 2026-11-03T15:14:16+07:00 feat: pass logout revocation and goal-date rules with persisted auth and goal
    APIs
ee14477 2026-11-03T18:23:51+07:00 docs: reconcile B feature contracts with A foundation before implementation
0e1ca17 2026-11-03T18:25:21+07:00 test: specify F02 manager creation, validation and access before
    implementation (#4)
a3769d4 2026-11-03T18:29:02+07:00 feat: add manager activity templates and catalog recovery (#4)
d709741 2026-11-03T18:32:48+07:00 test: specify F04 dates, progress, ownership and concurrent entries before
    code (#5)
0b51571 2026-11-03T18:45:20+07:00 test: await completed logout and verify entry persistence across real process
    restart (#5)
db199eb 2026-11-03T20:17:43+07:00 test: reproduce PR review localhost-alias isolation bypass
d2efada 2026-11-03T20:19:29+07:00 fix: normalize localhost case and trailing DNS dot in test isolation guard
```

Two sampled completed issue chains: Issue4/F02 -> codex/f02-templates -> PR6 -> A substantive approval on ec681e9 -> staging18e5882; Issue5/F04 -> codex/f04-entries-progress -> PR7 -> A substantive approval on36fc9b6 -> staging85f510f. Both were closed and markedDone after feature acceptance. PR3 A/F01/F03 was reviewed by B with a concrete guard finding and subsequent corrected-head approval, staging1a4b74b. Staging-to-main PR9 was authored by Datakung, separately approved by auto4496 at0c0915e, and merged asdf08ec19cdeb0efcfbfbee92f3d385d87059528c; tagv0.1.0-sprint1 records the accepted version. Clean-main checks are the primary current results above.

## Actual board snapshot; feature completion and final release are distinct

| Work item | Status | Reference |
|---|---|---|
| F-01: project foundation and real identity/access | Done | https://github.com/auto4496/studytrack/issues/1 |
| F-03: own goals, validation and persisted target versions | Done | https://github.com/auto4496/studytrack/issues/2 |
| Add member A authentication and personal reading goals | Done | https://github.com/auto4496/studytrack/pull/3 |
| F-02: manager templates, validation and persisted catalog | Done | https://github.com/auto4496/studytrack/issues/4 |
| F-04: daily entries, concurrent duplicate protection and progress | Done | https://github.com/auto4496/studytrack/issues/5 |
| Add manager-created activity templates and persisted catalog | Done | https://github.com/auto4496/studytrack/pull/6 |
| Record daily reading and retrieve date-effective progress | Done | https://github.com/auto4496/studytrack/pull/7 |

| Member | Contribution supported by history | Peer review / shared work |
|---|---|---|
| A / auto4496; ID suffix70 | Product/SRS/System SDS/data/auth foundation; F01/F03 contract/tests/implementation; guard correction; independent B verification; readiness/report assembly. | Reviewed B PR6/7 with actual66/16 and117/24 checks; integrated candidates, setup and evidence. B reviewed A PR3. |
| B / Datakung; ID suffix68 | Feature inventory/traceability/sprint/UI conventions; F02/F04 contracts/tests/implementation; daily progress/recovery/real restart evidence. | Reviewed A PR3, identified P2 guard defect and approved corrected head; supplied integration/handoff evidence. A reviewed B PR6/7. |

AI-assisted engineering: both members used Codex within a requirements-driven workflow. Work requests defined feature scope, shared interfaces, business rules, acceptance criteria and expected verification. Codex assisted with design, implementation, test preparation, execution and documentation. Generated changes were checked against versioned contracts, test assertions and actual build/test results; recorded failures and teammate-review findings guided corrections. Work remained traceable through Issues, feature branches, commits and reviewed integration. Acceptance relied on observable behavior and retained evidence rather than generated completion claims. AI-assisted review and execution are disclosed. Both members remain responsible for understanding and explaining the design, tests and released behavior.

## F7. Reproduction and final submission gates

Prerequisites: Node>=22.12, npm, Git, Docker Desktop/Linux PostgreSQL17 and Edge(Windows) or installed Playwright Chromium. See the commands below; environment examples contain placeholders and setup generates private random credentials.

```
npm ci
npm run setup:local
npm run db:up
npm run db:generate
npm run db:migrate
npm run db:seed
npm run dev
# Sequential verification on distinct TEST_DATABASE_URL:
npm run db:test:migrate
npm test
npm run build
npx playwright test --config playwright.member-b.config.ts
npx tsx scripts/member-b-restart.ts
```

Synthetic accounts: manager@studytrack.test uses private SEED_MANAGER_PASSWORD; student1@studytrack.test and student2@studytrack.test use private SEED_PARTICIPANT_PASSWORD. No password/token is embedded in the PDF. Seed reruns preserve existing accounts. Exact Origin/cookie/CSRF configuration must match the opened UI. The test guard normalizes localhost case/root-dot/loopback and refuses an equal dev target; never run destructive suites on development. If ports are occupied, configure alternate documented URLs/ports or an isolated PostgreSQL target without application-source changes.

Current limitations: F05..F08 remain planned; lifecycle consumers are tested through fixtures but no revision/archive/deactivate UI/API is claimed. No independent UAT, cloud deployment, required CI gate, containerized application or final video is claimed. Main release approval/merge/tag and both full student identities are recorded. Joint review of this PDF precedes course submission. Repository accessibility must be checked for the TA; Lab5 separately requires public visibility until grading ends. No visibility/billing/IAM operation is part of this preparation.

Before submission: both students check the final PDF, including page navigation, identities and release references, and ensure the assessor can access the repository. Submit one self-contained PDF per team through LEB2 by 8 November 2026 at 23:59 Asia/Bangkok. The reviewed Sprint 1 main release, immutable tag and clean-main results are recorded above. Submission remains pending. Later commits must not silently replace the assessed version.

## F8. Source and evidence index

Course sources: group_work_specs_v1.pdf (theme8, engineering workflow) and project_deliverable_1_v1.pdf (8 pages, PartsA-F, self-contained PDF and main-release requirements). Source documents are retained unchanged in repository sources/. Detailed baseline source files: docs/srs.md, docs/features.md, docs/traceability.md, docs/system-sds.md, docs/sprints/plan.md, docs/sprints/sprint-1/*.md and docs/integration-contract.md. Actual execution JSON/logs, selected screenshots and review manifests are under artifacts/evidence/. The engineering content required for assessment is embedded in this PDF; links support targeted verification.